CS6530 Applied Cryptography

Course Project – Theme 2: Post-Quantum Secure Messaging

Phase 1 Technical Report

Akhilesh K.R	CS26E001
D R Santhosh	CS26E004
Mysha Ali	CS26E008

Primary Paper

K. Bhargavan, C. Jacomme, F. Kiefer and R. Schmidt,
"Formal Verification of the PQXDH Post-Quantum Key Agreement Protocol
for End-to-End Secure Messaging,"
33rd USENIX Security Symposium, 2024.

Jul–Nov 2026

Abstract

Post-quantum migration of secure-messaging protocols is not simply a matter of replacing a classical cryptographic primitive with a post-quantum one. The resulting security also depends on protocol composition, identity and key binding, compromise assumptions and the correspondence between the formal specification and the deployed implementation. This project studies PQXDH, the post-quantum extension of the X3DH asynchronous key-agreement protocol, through the formal analysis presented by Bhargavan et al.

Phase 1 focuses on the system and security understanding of PQXDH and on a selected specification/security finding from the primary paper. The report describes the protocol setting, relevant key material, security objectives, attacker capabilities and compromise assumptions. It then analyzes the KEM re-encapsulation issue, distinguishing the formal specification result from the protection provided by the Kyber-based Signal implementation. The finding illustrates why a protocol-level binding property is required in addition to generic KEM security.

For Phase 2, the team proposes to reproduce the selected KEM re-encapsulation result and its corresponding corrected result using the official PQXDH analysis artefact.

Contents

Abstract **1**

1 Project and Problem Understanding **2**
- 1.1 Primary Paper . . . 2
- 1.2 Project Question . . . 2

2 Activity 1: System and Security Understanding **3**
- 2.1 PQXDH System and Protocol Overview . . . 3
- 2.2 Protocol State and Key Material . . . 3
- 2.3 Classical and Post-Quantum Contributions . . . 4
- 2.4 Security Objectives . . . 4
- 2.5 Trust and Compromise Assumptions . . . 4
- 2.6 Attacker Capabilities . . . 4
- 2.7 Migration and Coexistence . . . 4

3 Activity 2: Security and Specification Analysis **5**
- 3.1 Selected Finding: KEM Re-Encapsulation . . . 5
- 3.2 1. Intended Security Property . . . 5
- 3.3 2. Specification Assumption . . . 5
- 3.4 3. What the Formal Model Revealed . . . 5
- 3.5 4. Was the Issue Exploitable in Signal? . . . 5
- 3.6 5. Implementation Behaviour Providing Protection . . . 5
- 3.7 6. Specification Correction . . . 6
- 3.8 7. Security Interpretation . . . 6
- 3.9 Specification Versus Implementation . . . 6
- 3.10 Phase 1 Summary . . . 6

4 Selection for Phase 2 **7**

5 Individual Contribution Statement **7**

6 Generative-AI Usage Declaration **7**

7 Conclusion **7**

1 Project and Problem Understanding

Secure messaging protocols must establish shared session keys over an untrusted network while providing authentication, confidentiality and forward secrecy. X3DH addresses this requirement in an asynchronous setting, where a recipient can be offline and publishes prekey material in advance. This allows an initiator to begin a secure session without requiring the recipient to be online at the exact time of initiation.

The motivation for PQXDH comes from the *harvest-now-decrypt-later* (HNDL) threat. An attacker can record encrypted communication today and retain the ciphertext until a future time when a sufficiently capable quantum computer may break classical public-key assumptions. A secure post-quantum migration should therefore protect historical communication against the relevant future threat model.

PQXDH adds a post-quantum key-encapsulation mechanism (KEM) contribution to the X3DH-style key agreement. The central engineering issue is that the addition of a new primitive changes the security argument of the complete protocol. Identity binding, prekey binding, KEM-key binding, transcript context, compromise assumptions and implementation behaviour must all remain consistent.

1.1 Primary Paper

The primary paper by Bhargavan et al. formally studies the security of PQXDH using ProVerif and CryptoVerif. The paper examines the role of X3DH, the motivation for PQXDH, the HNDL threat, the protocol's long-term and ephemeral keys and the security properties expected from the protocol.

A particularly relevant result is the identification of specification problems that do not necessarily translate directly into exploitable vulnerabilities in the deployed Signal application. The analysis therefore distinguishes between what follows from an abstract protocol specification and what is protected by implementation-specific choices.

One of the selected findings is the **KEM re-encapsulation issue**. It shows that a conventional KEM security assumption does not by itself express all of the binding properties required by the protocol. The security argument must connect the KEM shared secret to the correct public key and protocol execution.

1.2 Project Question

The main question considered in this project is:

> *Does adding a post-quantum KEM to an already deployed secure messaging protocol preserve the intended security properties, or can specification and binding assumptions introduce new security failures?*

This question motivates both the system/security analysis in Phase 1 and the bounded formal reproduction planned for Phase 2.

2 Activity 1: System and Security Understanding

2.1 PQXDH System and Protocol Overview

PQXDH is designed for asynchronous end-to-end messaging. The main logical entities are:

- **Alice**: the initiator of the key agreement.
- **Bob**: the recipient, who may be offline when Alice starts the protocol.
- **Prekey server**: stores and distributes Bob's public key and prekey material and may relay messages.

The server is part of the communication infrastructure but is not intended to learn the session key. The protocol therefore has to provide security even though the communication network and relay infrastructure cannot be treated as fully trusted.

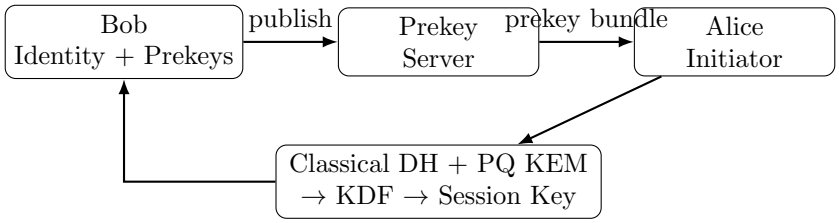


Figure 1: Simplified PQXDH system and key-establishment model.

2.2 Protocol State and Key Material

The protocol contains several types of key material with different lifetimes. Their different roles are important to the security argument.

Material	Lifetime	Purpose
Identity key	Long-term	Associates protocol material with the user's identity.
Signed prekey	Medium-term	Provides an authenticated asynchronous DH contribution.
One-time prekey	One-use	Provides an additional fresh classical contribution.
Ephemeral key	Per session	Provides fresh initiator-side material.
PQ KEM key	Prekey/session	Provides the post-quantum contribution.
KEM ciphertext/shared secret	Per session	Completes the PQ KEM exchange.
Session key	Per session	Protects subsequent secure communication.

Table 1: Relevant PQXDH cryptographic state.

At a high level, Alice retrieves Bob's authenticated prekey material, performs the classical DH operations and a PQ KEM operation, and combines the resulting secret material using a KDF. Bob performs the corresponding operations and derives the same session key.

The important point is that the KEM contribution is not independent of the rest of the protocol. The selected KEM key, its ciphertext, the peer identity and the resulting shared secret must remain associated with the same protocol execution.

2.3 Classical and Post-Quantum Contributions

X3DH provides the original asynchronous classical key-agreement structure. PQXDH retains this structure while adding a post-quantum KEM contribution.

Conceptually,

$$\text{classical DH contributions} + \text{PQ KEM shared secret} \longrightarrow \text{KDF} \longrightarrow \text{session key}.$$

The purpose of the PQ contribution is not merely to increase the number of cryptographic operations. It is intended to preserve confidentiality of historical sessions against a future quantum-capable attacker under the specified assumptions.

2.4 Security Objectives

The main security objectives relevant to the Phase 1 study are:

- **Authentication:** the communicating parties should be associated with the intended identities under the protocol's authentication assumptions.
- **Confidentiality:** an attacker observing the network should not recover the session key or protected message contents.
- **Forward secrecy:** compromise of specified long-term material should not automatically expose protected past sessions.
- **Post-quantum forward secrecy:** the PQ contribution should protect recorded sessions against the HNDL threat within the model.
- **Key and identity binding:** the selected keys and KEM contribution must remain associated with the intended protocol context.

2.5 Trust and Compromise Assumptions

The formal security claims are conditional on the compromise model. The attacker is not assumed to possess every secret simultaneously. Instead, specific compromise events are modeled, such as compromise of particular long-term keys.

The prekey server distributes public material and messages but is not supposed to learn the resulting session key. Long-term identity material is assumed to satisfy the authentication assumptions of the protocol. The post-quantum KEM is assumed to satisfy the cryptographic properties required by the formal security argument.

2.6 Attacker Capabilities

The security analysis considers an active network attacker capable of interfering with protocol communication according to the formal model. This includes observing, intercepting and modifying messages and attempting to cause protocol participants to accept attacker-controlled values.

The formal model also permits selected long-term key compromise. This is important because forward secrecy claims are meaningful only relative to clearly stated compromise events.

A useful distinction is therefore:

network control vs. **specified key compromise** vs. **complete endpoint compromise**.

The project analysis focuses on the first two categories rather than assuming unrestricted compromise of a running endpoint.

2.7 Migration and Coexistence

PQXDH represents a migration of an existing secure-messaging design rather than a completely new protocol. The migration must preserve the original asynchronous communication model while adding a post-quantum contribution.

Therefore, the migration problem involves:

- maintaining identity authentication;
- correctly integrating the PQ KEM;
- preserving intended forward-secrecy properties;
- binding new PQ material to the existing protocol context; and
- ensuring that implementation behaviour matches the intended specification.

3 Activity 2: Security and Specification Analysis

3.1 Selected Finding: KEM Re-Encapsulation

The KEM re-encapsulation issue is selected because it directly demonstrates the difference between primitive-level security and protocol-level security.

3.2 1. Intended Security Property

The intended property is that sessions using different PQ KEM keys remain independent. Compromise of one PQ KEM key should not allow an attacker to cause a different session, associated with another uncompromised KEM public key, to use a secret already known to the attacker.

This requirement contributes to the confidentiality and forward-secrecy argument of the protocol.

3.3 2. Specification Assumption

A conventional IND-CCA KEM security definition does not necessarily express every public-key/shared-secret binding property required by a protocol.

Suppose

$$(CT, SS) \leftarrow Encaps(PK_1).$$

If the attacker knows the secret key corresponding to PK_1, the attacker can obtain SS. A protocol-level problem arises if the attacker can then construct another ciphertext CT' for a different public key PK_2 such that

$$Decaps(SK_2, CT') = SS.$$

The same shared secret would then appear under a different public key. This violates the intended association between the session and the selected PQ key even though the underlying KEM has not necessarily violated its usual IND-CCA definition.

3.4 3. What the Formal Model Revealed

The formal analysis exposed this re-encapsulation possibility. The result shows that the PQXDH security argument needs a stronger relationship between the KEM public key and the resulting shared secret.

The important observation is that the issue comes from how the primitive is used inside the protocol. It is therefore a specification and composition problem rather than simply a claim that the KEM algorithm itself is cryptographically broken.

3.5 4. Was the Issue Exploitable in Signal?

The formal result does not automatically imply that the deployed Signal application was vulnerable.

The primary paper distinguishes the abstract specification from the implementation. The deployed implementation uses Kyber, and the authors establish an additional property that ties the KEM shared secret to the corresponding public key.

Consequently, the theoretical re-encapsulation attack does not directly apply to the deployed Kyber-based instantiation under the stated assumptions.

This distinction is central to the project:

formal specification weakness $\neq$ automatically exploitable implementation vulnerability

3.6 5. Implementation Behaviour Providing Protection

The protection is not simply the statement that Kyber is "post-quantum secure." The relevant property is that the shared secret is appropriately bound to the KEM public key.

Thus the protocol's security argument needs an assumption that matches the specific way the KEM is composed into PQXDH.

3.7 6. Specification Correction

The formal analysis motivated clarification of the PQXDH specification and stronger binding of the KEM public key to the authenticated protocol context.

The security reasoning can therefore be summarized as

$$\text{KEM security} + \text{KEM public-key binding} + \text{protocol binding} \Rightarrow \text{appropriate PQXDH security.}$$

This illustrates an important principle: a primitive can satisfy its standard security definition while still requiring additional properties when it is embedded into a larger protocol.

3.8 7. Security Interpretation

The finding can be understood through three layers:

1. **Primitive layer:** the KEM must satisfy its cryptographic security assumptions.
2. **Protocol layer:** the KEM key and resulting secret must be bound to the correct identity and protocol execution.
3. **Implementation layer:** the deployed implementation may provide additional protections that are not obvious from an abstract specification.

The formal analysis is valuable because it checks whether these layers actually support the claimed security properties.

3.9 Specification Versus Implementation

The selected issue also demonstrates why a formal weakness should not be described automatically as a deployed vulnerability.

A specification may permit behaviours that a particular implementation prevents. However, relying only on an implementation detail is weaker than making the required property explicit in the specification and security argument.

For this reason, the correction of the protocol specification is important even when the deployed implementation already contains additional protection.

post-quantum engineering reference. It demonstrates a working secure-session design that combines a post-quantum KEM with a KDF and authenticated encryption.

end-to-end messaging protocol. It therefore does not replace the PQXDH primary paper or the official PQXDH analysis artefact.

Its relevance is mainly illustrative: it shows that integrating a PQ primitive into a practical system also requires choices about key derivation, authenticated encryption, state and deployment. These concerns reinforce the project's broader focus on protocol composition.

3.10 Phase 1 Summary

The Phase 1 analysis establishes four main points:

- PQXDH adds a PQ KEM contribution to an asynchronous X3DH-style protocol to address the HNDL threat.
- Security depends on the binding between identities, keys, KEM ciphertexts and shared secrets.
- A formal specification issue does not necessarily imply an exploitable implementation vulnerability.
- The KEM re-encapsulation finding provides a bounded formal result suitable for Phase 2 reproduction.

4 Selection for Phase 2

For Phase 2, the team proposes to reproduce the **KEM re-encapsulation finding and its corresponding corrected result** using the official PQXDH analysis artefact.

The planned study is:

1. configure the author-provided analysis environment;
2. identify the relevant earlier model and security query;
3. reproduce the selected formal result;
4. run or inspect the corresponding corrected model;
5. compare the verification behaviour; and
6. explain the security significance of the correction.

The finding was selected because it provides a clear connection between cryptographic assumptions, protocol binding, formal verification and implementation behaviour. It also fits the course requirement that Phase 2 begin with a bounded reproduction rather than reproduction of every model in the paper.

5 Individual Contribution Statement

All three team members jointly studied the primary paper and reviewed the complete Phase 1 report so that each member can explain the system, security assumptions, Activity 2 finding and proposed Phase 2 work.

Member	Phase 1 contribution
Akhilesh K.R (CS26E001)	Studied the PQXDH system and protocol structure, including the relevant entities, prekey/key material and high-level protocol flow. Contributed to the Activity 1 system/security model and reviewed the security assumptions and protocol diagram.
Mysha Ali (CS26E008)	Studied the primary paper's formal security analysis and the KEM re-encapsulation finding. Drafted and reviewed the Activity 2 security and specification analysis, including the distinction between the formal specification and the deployed Signal implementation.
D R Santhosh (CS26E004)	Studied the HNDL motivation, security objectives, attacker/compromise assumptions and PQ migration context. Contributed to the project/problem understanding and Phase 2 selection, and reviewed the complete report for technical consistency.

Table 2: Individual contribution statement.

6 Generative-AI Usage Declaration

Generative AI was used as a learning and productivity aid during preparation of this report. It was used to clarify cryptographic concepts, organize the report structure, assist with technical writing and improve the presentation of the protocol model.

The team is responsible for the technical content and verified the relevant claims against the primary paper, the project requirement specification and the official PQXDH analysis artefact. AI-generated material was not treated as a substitute for understanding or verification.

7 Conclusion

PQXDH demonstrates that post-quantum migration of a deployed secure-messaging protocol is a protocol-level security problem rather than a simple primitive replacement. The KEM re-encapsulation issue shows how an apparently secure primitive can require additional binding properties when composed into a larger protocol.

References

[1] K. Bhargavan, C. Jacomme, F. Kiefer, and R. Schmidt, "Formal Verification of the PQXDH Post-Quantum Key Agreement Protocol for End-to-End Secure Messaging," in *33rd USENIX Security Symposium*, 2024, pp. 469–486.

[2] Inria-Prosecco, "pqxdh-analysis: Formal Analysis of the PQXDH Protocol," GitHub repository, 2024.